Informe final de seguridad: Sprint 10

Proyecto: Perfumería Victoria (tienda en línea de perfumes) · **Marco:** OWASP Top 10 (2025) · **Fecha:** 8 de noviembre de 2026 · **Ticket:** SFTWRKEY-453

1. Resumen ejecutivo

El Sprint 10 llevó la tienda a cobrar con tarjetas de verdad, guardar la sesión en una cookie que JavaScript no puede leer y cerrar el ciclo de compra con correos, comprobantes y reseñas. Cada función nueva entró con su fila en la matriz OWASP y su prueba. **Al cierre la matriz no tiene ningún riesgo abierto: ni crítico, ni alto, ni medio.**

Resultado	Sprint 8	Sprint 9	Sprint 10 (final)
Riesgos evaluados en la matriz	45	50	69
Riesgos en `Pasa`	37	47	69
Riesgos abiertos	3 (1 crítico, 2 medios)	2 (medios)	0
Verificaciones pendientes en producción	4	0	0
Vulnerabilidades en dependencias (frontend, backend, chatbot)	0, 0, 0	0, 0, 0	0, 0, 0
Alertas altas de OWASP ZAP (sitio y API en producción)	0	0	0

Riesgo residual: un riesgo bajo aceptado desde el Sprint 8 (SEC-34: el registro dice si un correo ya existe, necesario para que el cliente sepa que ya tiene cuenta). Además quedan tres temas de operación que no son vulnerabilidades pero afectan la entrega (sección 5).

2. Riesgos cerrados en el sprint

ID	Riesgo	Severidad	Tarea	Evidencia
SEC-33	Contraseñas de 6 caracteres	Media	SFTWRKEY-409, 453	Mínimo 12 caracteres y máximo 72 bytes en registro, alta de usuarios, cambio y recuperación de contraseña; el navegador valida con la misma regla (`passwordPolicy.test.js` , `passwordPolicy.test.ts`)
SEC-50	Cuentas de prueba con contraseña pública en producción	Media	SFTWRKEY-453	Las tres cuentas se borraron; el seed ya no las crea. Desde el 08/11/2026 la base de producción es nueva y solo tiene la cuenta de administrador
SEC-35	Token de sesión en `localStorage` (aceptado desde el Sprint 8)	Media	SFTWRKEY-451	La sesión vive en la cookie `luxor_sesion` (`HttpOnly` , `Secure` , `SameSite=Lax`); el sitio habla con la API por su mismo dominio. Probado en Chromium, Firefox y WebKit (`e2e/sesion.spec.ts` , `session.test.js`)
SEC-07, SEC-31	El límite de intentos de login no distinguía visitantes detrás de Vercel y Cloudflare: en producción 24 logins fallidos seguidos no recibieron ningún bloqueo	Alta	SFTWRKEY-453	`services/clientIp.js` toma la IP real del visitante (`clientIp.test.js` , 7 pruebas). **Verificado en producción el 08/11/2026:** 12 logins fallidos seguidos por el sitio, del 1 al 10 responden 401 y el 11.º y el 12.º responden 429

3. Riesgos nuevos del sprint

Todas las funciones nuevas se evaluaron antes de entrar a producción. Ninguna quedó abierta.

ID	Riesgo	Severidad	Tarea	Control y prueba
SEC-56	El número de tarjeta o el CVV pasan por el servidor o quedan en la base o en los logs	Crítica	SFTWRKEY-445	El cliente paga en la página de Recurrente; el servidor solo guarda la marca y los últimos 4 dígitos

ID	Riesgo	Severidad	Tarea	Control y prueba
SEC-57	Marcar un pedido como pagado sin pagar, repetir la confirmación o pagar menos	Crítica	SFTWRKEY-445	El pedido solo se crea cuando el backend le confirma el cobro a Recurrente, con el monto que armó el servidor (`checkout.integration.js` , 18 pruebas)
SEC-59	Un aviso de pago falso o repetido crea pedidos o descuenta stock dos veces	Crítica	SFTWRKEY-446	Firma Svix verificada en cada aviso (sin firma válida → 401) e identificador del pago único (`webhookSignature.test.js` , `paymentWebhooks.integration.js`)
SEC-58	La llave de Recurrente expuesta en el repositorio o en el frontend	Alta	SFTWRKEY-445	Solo vive en las variables de entorno de Render
SEC-66	Rol Mayorista: un cliente se da el descuento, o el admin convierte por error una cuenta de administrador	Alta	Feedback del cliente	Solo el admin cambia roles y nunca toca una cuenta ADMIN; el descuento lo calcula el servidor con el rol de la base (`wholesale.integration.js` , 5 pruebas)
SEC-69	Descargar el comprobante en PDF de un pedido ajeno	Alta	SFTWRKEY-433	El PDF se arma con datos que la API solo devuelve al dueño del pedido o a un admin; otro usuario recibe 404 (`orderConfirmation.test.js` , `userOrders.test.js`)
SEC-60	CSRF con la sesión en una cookie	Media	SFTWRKEY-451	`SameSite=Lax` y revisión del origen en toda petición que cambia datos (`security.sprint10.test.js`)
SEC-61	Manipular el costo de envío o el local de entrega	Media	SFTWRKEY-449	El envío lo calcula el servidor; uno enviado por el navegador se ignora (`checkout.integration.js`)
SEC-51, 53	HTML inyectado en los correos, o correos que llegan a otra persona	Media	SFTWRKEY-447, 448	Todo valor se escapa y el destinatario sale del pedido en la base
SEC-55	El chatbot da pedidos ajenos o sirve para adivinar números de pedido	Media	SFTWRKEY-458	Solo responde si el número y el correo coinciden, con clave interna y límite de intentos (`orderLookup.test.js` , 9 pruebas)
SEC-62, 67	Subir archivos que no son imágenes (SVG con script, HTML) en fotos de productos y de perfil	Media	SFTWRKEY-457, feedback	Se revisa que sea una imagen real y se guarda siempre convertida a WebP (`productImages.integration.js` , `avatars.integration.js`)
SEC-64, 65	Reseñas falsas, ajenas o con XSS	Media	SFTWRKEY-431	Solo quien recibió el perfume puede reseñarlo, una vez por pedido; el comentario se muestra como texto
SEC-52, 54, 63, 68	Fallos del correo que frenan la compra, analítica con datos personales, herramientas de desarrollo vulnerables, sesión vencida sin aviso	Baja	Varias	Ver la matriz

4. Pruebas y escaneos finales

Dependencias (08/11/2026). `npm audit` del frontend encontró una vulnerabilidad moderada nueva en `minimatch` (GHSA-g3hv-75wg-m249), usada solo por la herramienta de lint, nunca en el navegador. Se corrigió fijando `minimatch` 11.0.1 o superior para esa herramienta (`overrides` en `package.json`); el lint sigue funcionando igual.

Parte	Herramienta	Resultado	Anexo
Frontend	`npm audit`	0 vulnerabilidades (0 en lo que llega al navegador)	npm-audit-frontend-final.txt
Backend	`npm audit`	0 vulnerabilidades	npm-audit-backend-final.txt
Chatbot	`pip-audit`	Sin vulnerabilidades conocidas	pip-audit-chatbot-final.txt

OWASP ZAP en producción.

Alcance	Fecha	Resultado	Anexo
Sitio en producción (ZAP-03)	27/10/2026	0 altos, 0 bajos; 3 medios ya aceptados (CSP `img-src https:` , `style-src 'unsafe-inline'` que exige Google Sign-In y `Access-Control-Allow-Origin: *` en archivos estáticos públicos)	zap-frontend-produccion-sprint10.html
API en producción (ZAP-04)	27/10/2026	0 altos, 0 medios, 0 bajos; 1 informativo (el catálogo público se puede guardar en caché)	zap-api-produccion-sprint10.html

Revisión de cabeceras en producción el 08/11/2026, después de los últimos cambios (lo que el escaneo pasivo de ZAP revisa en cada respuesta): el sitio y la API responden con HSTS de un año, `X-Content-Type-Options: nosniff` , protección contra clickjacking (`X-Frame-Options` y `frame-ancestors`), CSP, `Referrer-Policy` y `Permissions-Policy` , y la API no expone `X-Powered-By` . Un pedido a la API desde otro sitio recibe solo el origen de la tienda en `Access-Control-Allow-Origin` , nunca el suyo.

Pendiente: repetir el escaneo con ZAP sobre producción después de los cambios del 28/10 al 08/11 (rol Mayorista, foto de perfil, comprobante en PDF, mapas). Esos cambios agregan rutas con sesión que el escaneo pasivo sin sesión no recorre; sus controles están cubiertos por las pruebas de las filas SEC-66 a SEC-69.

Pruebas automáticas al cierre: 433 pruebas unitarias de backend, 64 de integración y 12 de regresión contra PostgreSQL real, 203 de frontend, 138 del chatbot y 8 recorridos de extremo a extremo en navegador real (Chromium, y la sesión también en Firefox y WebKit). El CI corre todas en cada push a `main` .

5. Temas que quedan y recomendaciones

No son vulnerabilidades, pero el cliente debe conocerlos antes de recibir la plataforma.

Tema	Recomendación
La base de datos del plan gratuito de Render vence el 8 de diciembre de 2026 (la anterior venció el 6 de noviembre y el sitio estuvo caído dos días)	Pasar a un plan pagado o a un proveedor sin vencimiento antes de esa fecha, y programar respaldos
Sin dominio propio, los correos salen de una dirección genérica y Resend rechaza envíos a otros destinatarios	Comprar el dominio (SFTWRKEY-454), verificarlo en Resend y configurar `MAIL_FROM`
Login con Google apagado en producción	Al cargar el id de cliente OAuth en Vercel y Render, repetir en producción las pruebas de SEC-36
Recurrente en modo de pruebas	Al pasar a cobros reales, cambiar las llaves de Render por las de producción y repetir una compra real de monto bajo

6. Anexos

- Matriz OWASP, con las 69 filas y su estado.
- Auditorías de dependencias: frontend, backend, chatbot.
- Escaneos de ZAP en producción: sitio y API.
- Informes anteriores: Sprint 8 y Sprint 9.